

Cleya.ai Edge Case Testing - Executive Summary

Critical Findings (Immediate Action Required)

● CRITICAL Vulnerabilities

- 1. Development Mode Exposed in Production**
 - /api/health endpoint reveals env: "development"
 - Debug information and stack traces may be exposed
- 2. SQL Injection Vulnerable**
 - Payload: ' OR '1'='1 causes 500 error (not proper rejection)
 - Payload: '; DROP TABLE users; -- causes 500 error
 - Indicates insufficient input sanitization
- 3. XSS Vulnerable**
 - <script>alert('XSS')</script> accepted in name field
 - causes 500 error
 - No output encoding visible
- 4. NoSQL Injection Vulnerable**
 - {"\$ne": null} operator causes 500 error
 - MongoDB-style injection possible
- 5. No Input Length Validation**
 - 10,000+ character inputs accepted
 - Null bytes (\x00) accepted
 - Control characters accepted

● HIGH Risk Issues

- 6. Information Leakage via 500 Errors**
 - Multiple invalid inputs return 500 instead of 400
 - May expose stack traces and system details
- 7. Admin Panel Accessible**
 - /admin endpoint returns loading page without auth
 - Potential unauthorized access to admin functions
- 8. No Rate Limiting**
 - No CAPTCHA on forms
 - No throttling on API endpoints
 - Susceptible to brute force and DoS

Test Results Summary

Category	Status
Cold Start Testing	✗ Failed - No validation on minimal profiles
Duplicate Detection	⚠ Weak - Unicode homoglyphs accepted
Extreme Outliers	✗ Failed - No length limits
Conflicting Intent	⚠ Weak - No role validation
Gaming Prevention	✗ Failed - No rate limiting
Data Quality	✗ Failed - Special chars accepted
API Security	✗ Failed - Multiple injection vectors

Quick Remediation Checklist

- Switch NODE_ENV to production
- Implement parameterized queries for all database operations
- Add input sanitization (DOMPurify for XSS, validator.js for inputs)
- Set maximum length limits on all fields
- Return 400 errors for validation failures (not 500)
- Add rate limiting middleware
- Implement CAPTCHA on signup/login
- Add security headers (CSP, X-Frame-Options, etc.)
- Normalize Unicode input (NFKC)
- Secure /admin endpoint with authentication

Files Generated

1. /mnt/okcomputer/output/cleya_edgecase_test.md - Full detailed report
2. /mnt/okcomputer/output/cleya_edgecase_summary.md - This executive summary

Risk Rating: HIGH

Recommended Action: Immediate remediation required